

פרק 5 – מניעת חדירה לרשת המקומית והרחבה (IDS / IPS)

11 שעות עיוני + 3 מעשי · שבועות 13-16

מטרות: מערכות זיהוי פלישה (IDS) · מערכות מניעת פלישה (IPS) · הגדרה ב-CLI · ניטור ופתרון תקלות
בבגרות: ההבדל IDS/IPS (ניטור+התראה מול ניטור+חסימה אוטומטית)

לפני שמתחילים – במה זה שונה מחומת אש? (למי שאין רקע)

חומת אש (פרק 4) בודקת סימנים תובנות – "מי מדבר עם מי ובאיזו דלת". היא לא מסתכלת מה בתוך החבילה. IDS/IPS מסתכלות על נכותה של החבילה ועל תוגהנתה – ומחפשות סימנים של התקפה, גם אם הפורט מותר. **אנלוגיה:** חומת אש = שומר שבדק תעודת זהות בכניסה. IDS/IPS = מצלמות אבטחה + מאבטח בתוך הבניין שמזהים התנהגות חשודה גם של מי שנכנס חוקית. IDS (Detection) = מצלמה שהעירתם אם רואה משהו חשוד (אבל לא עוצרת). IPS (Prevention) = מאבטח שרצוץ את החשוד במקום. **חתימה** (Signature) = "תמונת מבוקש" – תבנית ידועה של התקפה שהמערכת מחפשת.

5.1 למה חומת אש לא מספיקה

חומת אש (פרק 4) מחליטה לפי כתובות ופורטים. אבל התקפה יכולה להגיע בדיוק בפורט שפתחנו: SQL injection בתוך בקשת HTTP לפורט 80, ניצול חולשה בשרת המייל בפורט 25, או תולעת שמתפשטת דרך SMB שאנחנו מאפשרים בין סניפים. חומת האש רואה "TCP 80 ל-web server – מותר" ולא מסתכלת מה בתוך החבילה. כאן נכנסות מערכות IDS/IPS: הן מסתכלות על **התוכן** וההתנהגות ומחפשות סימנים של התקפה.

סיפור מהחיים: 10 דקות של Slammer (2003)

תולעת SQL Slammer הייתה חבילת UDP אחת בגודל 376 בתים לפורט (Microsoft SQL) 1434 כל שרת נגוע שלח אותה לכתובות אקראיות בקצב מרבי. תוך 10 דקות נדבקו 75,000 שרתים; כספומטים של Bank of America הפסיקו לעבוד, חלק מטיסות Continental בוטלו, ו-911 בסיאטל נפל. מי שהיה עם IPS מעודכן – חתימה אחת ("UDP 1434, גודל 376, המחרוזת הזו") חסמה את זה מיד. מי שהיה רק עם חומת אש שאיפשרה SQL בין הסניפים – נדבק. ומה שמדהים: מיקרוסופט פרסמה תיקון 6 חודשים קודם.

IDS 5.2 מול IPS – ההבדל המהותי

	Intrusion Detection – IDS System	Intrusion Prevention – IPS System
הגדרה (כמו בבגרות)	מערכת ניטור שנועדה לספק התראות בעת ניסיונות חדירה	מערכת ניטור שמאפשרת זיהוי וחסימה אוטומטית של ניסיונות חדירה
מיקום	מחוץ לנתיב (out-of-band, promiscuous); מקבלת עותק של התעבורה דרך SPAN/TAP	בתוך הנתיב (inline): התעבורה עוברת דרכה, חבילה אחר חבילה
תגובה	התראה (syslog), מייל, רישום; יכולה לבקש מחומת אש/נתב לחסום אחרי שהחבילה הראשונה כבר עברה, או לשלוח TCP reset	מפילה את החבילה הזדונית עוד לפני שהגיעה ליעד; חוסמת את החיבור/התוקף
השפעה על הרשת	אפס השהיה; אם ה-IDS נופל – הרשת ממשיכה	מוסיפה השהיה (latency); אם ה-IPS נופל – או שהרשת נופלת (fail-closed) או שעוברים ללא הגנה (fail-open)
מחיר של טעות (false positive)	התראה מיותרת – מטריד	תעבורה לגיטימית נחסמת – פוגע בעסק. לכן IPS דורש כוונות קפדני
מה היא רואה	יכולה לפספס חבילות בעומס (עותק)	רואה הכול, כולל חבילות שהיא עצמה מפילה

	Intrusion Detection - IDS System	Intrusion Prevention - IPS System
מקרי שימוש	ניטור, forensics, סביבה שלא סובלת חסימה בטעות	הגנה בזמן אמת בקצה ובין אזורים

שאלת תלמיד: "אז למה שמישהו יבחר IDS, אם IPS גם מזהה וגם חוסם?"

שלוש סיבות: (1) **סיכון של false positive** - בבית חולים או בבורסה, לחסום תעבורה לגיטימית בטעות גרוע יותר מלהחמיץ התקפה; מתחילים ב-IDS, מכווננים, ורק אז עוברים ל-IPS. (2) **ביצועים** - IPS inline על קו 100Gbps הוא ציוד יקר מאוד; IDS על עותק יכול לדגום. (3) **נראות** - IDS פנימי (על SPAN של המתג המרכזי) רואה תנועה רוחבית בין מחשבים שלא עוברת דרך שום חומת אש. בפועל ארגונים מפעילים את שניהם. ורוב מוצרי ה-IPS ניתנים להגדרה במצב IDS (monitor-only).

5.3 מבוסס-מארח (HIPS) מול מבוסס-רשת (NIPS)

	Host-based - HIPS	Network-based - NIPS
איפה	תוכנה על השרת/המחשב עצמו (agent)	מכשיר/מודול בנתיב הרשת (ASA עם מודול IPS, Firepower, IOS IPS, Snort/Suricata)
מה רואה	הכול במחשב: קריאות מערכת, קבצים, registry, זיכרון, ותעבורה מוצפנת אחרי הפענוח	תעבורת רשת בלבד; לא רואה לתוך TLS בלי SSL inspection
יתרון	מגן גם כשהמחשב מחוץ לרשת (לפטופ בבית); מבין את ההקשר (איזו אפליקציה)	מכשיר אחד מגן על מאות מחשבים; לא צורך מערכת ההפעלה; רואה סריקות ו-DoS
חסרון	התקנה ותחזוקה בכל מחשב; צורך משאבים; תלוי במערכת ההפעלה	עיוור למה שקורה בתוך המארח ולתעבורה מוצפנת
דוגמה	Cisco Security Agent (CSA) - מוזכר בתכנית; הופסק ב-2010 Cisco Secure Endpoint (היום: AMP), CrowdStrike, Microsoft Defender EDR - התחום נקרא EDR	Cisco Firepower NGIPS, Snort (קוד פתוח, שנרכש על ידי סיסקו), Palo Alto Suricata, Threat Prevention

CSA עבד לפי גישה התנהגותית ולא לפי חתימות: הוא יירט קריאות מערכת (system calls) ועצר התנהגות חשודה - "תוכנה שהגיעה במייל מנסה לשנות את ה-registry ולפתוח פורט" - גם בלי להכיר את הנוזקה. זה הרעיון של HIPS מודרני.

5.4 שיטות זיהוי

שיטה	איך	יתרון	חסרון
מבוססת חתימות (Signature / pattern)	השוואה לתבניות ידועות של התקפות (מחרוזת, רצף חבילות)	מדויקת, מעט false positive, קלה להבנה	לא מזהה התקפה חדשה (zero-day); דורשת עדכונים
מבוססת אנומליה (Anomaly / profile)	לומדת "מה נורמלי" (baseline) ומתריעה על חריגה - פתאום 500 חיבורי SSH בדקה	מזהה התקפות לא מוכרות	הרבה false positive; אם ה-baseline נלמד בזמן התקפה - היא "נורמלית"
מבוססת מדיניות (Policy)	המנהל מגדיר כללים: "אסור Telnet מרשת X"	פשוט, מדויק לארגון	מוגבל למה שחשבו עליו

שיטה	איך	יתרון	חסרון
מבוססת פיתיון (Honeypot)	מערכת "מזמינה" שאין לה שימוש לגיטימי - כל גישה אליה חשודה	אפס false positive; לומדים על התוקף	לא מגן ישירות; דורש תחזוקה
מוניטין (Reputation)	רשימות של IP/דומיינים (Cisco זדוניים ידועים Talos)	מהיר	תוקף חדש לא ברשימה

5.5 חתימות (Signatures)

חתימה היא תיאור של תבנית התקפה שה-IPS מחפש. חתימות מקובצות ב**קובץ חתימות** (Signature pack- age / SDF) שסיסקו מעדכנת; לכל חתימה מזהה (ID) ותת-מזהה (subsig), ולכל אחת **מנוע** (micro-engine) שמתאים לסוג - atomic-ip, service-http, string-tcp, multi-string ועוד.

אטומית מול מורכבת - נשאל בתכנית

	חתימה אטומית (Atomic)	חתימה מורכבת (Composite / Stateful)
מה בודקת	חבילה אחת ובודדת - למשל: "ICMP echo עם גודל < 1000" או "TCP עם דגלי SYN+FIN יחד" (לא חוקי)	רצף של חבילות/אירועים לאורך זמן - למשל: "יותר מ-100 SYN לפורטים שונים באותו מארח תוך 5 שניות" (port scan), או מחרוזת שמפוצלת בין כמה חבילות
זיכרון/מצב	לא צריך לשמור מצב - מהיר וזול	חייבת לזכור (state), עד "חלון אירועים" (event horizon)
דוגמה	Ping of Death, LAND attack (מקור = יעד)	SYN flood, סריקת פורטים, brute force

תכונות של חתימה

- Enabled / Disabled - פעילה או לא (מושבבת = טעונה בזיכרון אך לא בודקת).
- Retired / Unretired - בפנסיה = לא טעונה לזיכרון כלל (חוסך משאבים). כדי להשתמש בחתימה היא צריכה להיות unretired וגם enabled.
- Severity - informational / low / medium / high.
- Fidelity rating (SFR) - עד כמה החתימה מדויקת (0)-(100).
- Action - מה לעשות כשיש התאמה (ראו 5.6).
- קטגוריות** - ב-IPS IOS: ios_ips basic (חתימות בסיסיות, לנתב עם זיכרון מועט) ו- ios_ips ad-vanced.

5.6 פעולות (Actions) ואזהקות (Alarms)

מה IPS יכול לעשות כשחתימה תואמת

פעולה	משמעות
produce-alert	שלח התראה. (syslog / SDEE) ברירת מחדל ברוב החתימות.
produce-verbose-alert	התראה + עותק של החבילה (לניתוח).
deny-packet-inline	הפל את החבילה הזו.
deny-connection-inline	הפל את כל החבילות של החיבור (TCP flow) הזה.

פעולה	משמעות
deny-attacker-inline	הפל כל תעבורה מכתובת התוקף לזמן מוגדר - החזק ביותר, והמסוכן ביותר ב-false positive.
reset-tcp-connection	שלח TCP RST לשני הצדדים - היחידה שגם IDS (מחוץ לנתיב) יכולה לבצע.

ארבעה סוגי תוצאות - חובה להבין

לא הייתה התקפה	הייתה התקפה	המערכת התריעה
False Positive - אזעקת שווא; מטריד, וב-IPS חוסם משהו לגיטימי	True Positive - מצוין	
True Negative - מצוין	False Negative - הכי גרוע: התקפה עברה בשקט	המערכת שתקה

שאלת תלמיד: "מה יותר גרוע - false positive או false negative?"

תלוי במערכת. ב-IDS false positive זה רק רעש; false negative זה פריצה שלא ראינו - גרוע. ב-IPS false positive חוסם עסק (הזמנות לא נכנסות, טלפוניה נופלת) - זה מה שמפחיד מנהלים ולכן הם מעדיפים לפעמים לכבות חתימות; ואז מגיע ה-false negative. האיזון נקרא **כוונון** (tuning) - מכבים חתימות לא רלוונטיות (חתימות ל-IIS ברשת של Linux, מעלים סף, ומחריגים כתובות מהימנות. אין תשובה אחת; זה מה שעושים אנשי SOC כל היום.

5.7 ניטור IPS

- Syslog - ההתראות נשלחות כהודעות (Sig:2004 Subsig:0 Sev:25) %IPS-4-SIGNATURE: (ICMP Echo Request [10.1.1.5:0 -> 10.2.2.2:0]).
- SDEE (Security Device Event Exchange) - פרוטוקול מבוסס HTTPS/XML שסיסקו יצרה כדי שתחנת ניהול תשלוק אירועים מה-IPS (pull) בצורה מאובטחת. דורש http secure-server ip.
- **תחנות ניהול:** בעבר IEV / IME / MARS (מוזכרים בחומרים ישנים); היום Firepower Management Center (FMC), או SIEM כללי (Splunk, QRadar, ELK) שמקבל syslog מכל המערכות ומבצע **קורלציה** - "אותו IP הופיע ב-IPS, בחומת האש וב-AD תוך דקה".

5.8 הגדרת IOS IPS ב-CLI

נתב סיסקו יכול לתפקד כ-IPS (מוגבל) בעצמו. התהליך המלא בציוד אמיתי:

1. הורדת חבילת חתימות (IOS-Sxxx-CLI.pkg) ומפתח ציבורי (realm-cisco.pub.key.txt) מ-Cisco.com.
2. יצירת תיקייה ב-flash לחתימות.
3. הגדרת המפתח הציבורי (כדי שהנתב יודא שהחבילה חתומה על ידי סיסקו).
4. הגדרת IPS: שם, מיקום, התראות, קטגוריות.
5. החלה על ממשק וטעינת החבילה.

! שלב 2 - תיקייה

```
R1# mkdir ipsdir
```

! שלב 3 - מפתח ציבורי של סיסקו (מעתיקים מהקובץ; קטע מקוצר)

```
R1(config)# crypto key pubkey-chain rsa
```

```
R1(config-pubkey-chain)# named-key realm-cisco.pub signature
```

```
R1(config-pubkey-key)# key-string
```

```
R1(config-pubkey)# 30820122 300D0609 2A864886 ...
```

```
R1(config-pubkey)# quit
```

! שלב 4 - הגדרת ה-IPS

```
R1(config)# ip ips config location flash:ipsdir
R1(config)# ip ips name MYIPS ACL - רק תעבורה שתואמת ל-101 MYIPS list ip - אפשר !
R1(config)# ip ips notify log syslog - התראות ל- !
R1(config)# ip http secure-server
R1(config)# ip ips notify sdee ולתחנת ניהול !
R1(config)# ip ips signature-category
R1(config-ips-category)# category all
R1(config-ips-category-action)# retired true ! קודם - הכול בפנסיה
R1(config-ips-category-action)# exit
R1(config-ips-category)# category ios_ips basic
R1(config-ips-category-action)# retired false ! ואז - רק הבסיסיות פעילות
R1(config-ips-category-action)# exit
R1(config-ips-category)# exit
! שלב 5 - החלה על ממשק (בכיוון שממנו מגיעה התעבורה החשודה)
R1(config)# interface g0/0
R1(config-if)# ip ips MYIPS in
! טעינת חבילת החתימות (מ-TFTP/USB) - ב-Packet Tracer שלב זה לא קיים
R1# copy tftp://10.0.0.5/IOS-S416-CLI.pkg idconf
```

שינוי חתימה בודדת - הדוגמה הקלאסית: התראה + חסימה על ping

```
R1(config)# ip ips signature-definition
R1(config-sigdef)# signature 2004 0 2004/0 = ICMP Echo Request !
R1(config-sigdef-sig)# status
R1(config-sigdef-sig-status)# retired false
R1(config-sigdef-sig-status)# enabled true
R1(config-sigdef-sig-status)# exit
R1(config-sigdef-sig)# engine
R1(config-sigdef-sig-engine)# event-action produce-alert
R1(config-sigdef-sig-engine)# event-action deny-packet-inline
R1(config-sigdef-sig-engine)# exit
R1(config-sigdef-sig)# exit
R1(config-sigdef)# exit
Do you want to accept these changes? [confirm]
```

טיפ: מה עובד ב-Packet Tracer

Packet Tracer תומך בתת-קבוצה: ip ips config location, ip ips name, ip ips no-, ושינוי log tify, signature-category, (all retired / ios_ips basic), ip ips NAME in|out, ושינוי חתימה (ICMP echo) 2004 0 עם produce-alert ו-deny-packet-inline אין טעינת חבילה ואין SDEE. תרגיל ה-ping הוא התרגיל שעובד - ורואים בשרת ה-syslog את ההתראה ואת ה-ping נכשל. זה מספיק להמחשה.

5.9 וריפיקציה ופתרון תקלות

```
R1# show ip ips all ! סיכום: שם, ממשקים, קטגוריות, מספר חתימות טעונות
R1# show ip ips configuration
R1# show ip ips interfaces
R1# show ip ips signatures [count] ! אילו חתימות פעילות
R1# show ip ips statistics ! כמה חבילות נבדקו, כמה התראות
R1# clear ip ips statistics
R1# show ip ips sessions
```

תסמין	סיבה נפוצה ופתרון
אין התראות בכלל	ה-IPS לא מוחל על הממשק / בכיוון הלא נכון. תעבורה נכנסת מהאינטרנט ⇒ in על הממשק החיצוני. בדקו <code>show ip ips interfaces</code> .
0 signatures loaded"	קטגוריה all retired ולא unretired כלום; או חבילת חתימות לא נטענה (<code>copy ... idconf</code>); או מפתח ציבורי חסר/שגוי - הנתב דוחה חבילה לא חתומה.
הנתב איטי / CPU 100%	יותר מדי חתימות (advanced) על נתב קטן). השאירו <code>ios_ips basic</code> , השתמשו ב- <code>list ACL</code> כדי לבדוק רק תעבורה רלוונטית.
יש התראה אך החבילה עוברת	ה-action הוא <code>produce-alert</code> בלבד; הוסיפו <code>deny-packet-inline</code> או שהחתימה <code>enabled</code> . <code>retired</code> .
תעבורה לגיטימית נחסמת	<code>false positive</code> . זהו את החתימה ב- <code>syslog</code> . ובטלו/כווננו אותה; או השתמשו ב- <code>ip ips name</code> <code>list ACL</code> X להחריג.

5.10 מדריך פקודות מרוכז - פרק 5

פקודה	תפקיד
<code>mkdir ipsdir</code>	תיקייה לחתימות
<code>→ crypto key pubkey-chain rsa named-key realm-cisco.pub signature</code>	מפתח לאימות חבילה
<code>ip ips config location flash:ipsdir</code>	מיקום
<code>ip ips name NAME [list ACL]</code>	כלל IPS
<code>ip ips notify log sdee</code>	יעד התראות
<code>category → ip ips signature-category retired true → all</code>	כיבוי כל החתימות
<code>retired → category ios_ips basic false</code>	הפעלת הבסיסיות
<code>ip ips NAME in out</code> (ממשק)	החלה
<code>copy tftp://...pkg idconf</code>	טעינת חתימות
<code>→ ip ips signature-definition engine/status → signature ID SUB</code>	עריכת חתימה
<code>show ip ips all configuration signatures statistics</code>	ורפיקציה

5.11 תרגילים לתלמידים

תרגיל 1 - True/False Positive/Negative

סווגו: א. ה-IPS חסם עדכון Windows לגיטימי כי הוא "נראה כמו הורדת קובץ הרצה חשוד". ב. תולעת
עברה דרך ה-IDS בלי התראה כי החתימה לא עודכנה. ג. ה-IDS התריע על סריקת Nmap שאכן בוצעה. ד.
תעבורת Zoom עברה כרגיל ללא התראה.

א. False Positive. ב. False Negative. ג. True Positive. ד. True Negative.

תרגיל 2 – אטומית או מורכבת?

א. חבילת TCP עם כל 6 הדגלים דלוקים ("Xmas scan ב. 50 ניסיונות כניסה כושלים ל-SSH מאותו IP תוך דקה. ג. חבילת IP שבה כתובת המקור שווה לכתובת היעד. ד. מחרוזת /etc/passwd שמפוצלת בין שתי חבילות HTTP.

א. אטומית ב. מורכבת ג. אטומית (LAND) ד. מורכבת (דורשת הרכבת זרם)

תרגיל 3 – בחירת פעולה

לכל מצב בחרו את ה-action המתאים ביותר ונמקו: א. חתימה עם fidelity 30 (לא מדויקת) לפעילות חשודה קלה. ב. חתימה ל-SQL injection ודאית (fidelity 95) לשרת ה-web. ג. תוקף ששולח 10,000 SYN בשנייה. ד. IDS מחוץ לנתיב שזיהה session זדוני.

א. produce-alert בלבד – סיכון false positive גבוה. ב. deny-connection-inline (או deny-packet) + alert. ג. deny-attacker-inline – לחסום את המקור לזמן. ד. reset-tcp-connection – היחיד שזמין ל-IDS מחוץ לנתיב.

תרגיל 4 – תכנון פריסה

ציירו רשת: אינטרנט – נתב קצה – חומת אש – מתג מרכזי – (שרתים, משתמשים). סמנו היכן תמקמו IPS והיכן IDS, ונמקו. היכן תתקימו HIPS?

IPS inline בין חומת האש למתג המרכזי (או כמודול בחומת האש) – מגן על הכול מהאינטרנט. IDS על SPAN של המתג המרכזי – רואה תנועה רוחבית פנימית. HIPS/EDR על השרתים (בעיקר web, DB, DC) ועל מחשבי המשתמשים (ניידים).

5.12 שאלות בסגנון בגרות

שאלה 1

התאימו: מערכת _____ היא מערכת ניטור שמאפשרת זיהוי וחסומה אוטומטית של ניסיונות חדירה. מערכת _____ היא מערכת ניטור שנועדה לספק התראות בעת ניסיונות חדירה. (IDS / IPS / DNS / RADIUS / TACACS)

IDS · IPS

שאלה 2

מהו ההבדל במיקום ברשת בין IDS ל-IPS, ומה המשמעות לגבי השהיה?
IDS – מחוץ לנתיב (promiscuous), מקבל עותק ⇒ אין השהיה. IPS – בתוך הנתיב (inline), התעבורה עוברת דרכו ⇒ מוסיף השהיה.

שאלה 3

מה ההבדל בין חתימה אטומית לחתימה מורכבת?
אטומית – בודקת חבילה בודדת, ללא שמירת מצב. מורכבת – בודקת רצף חבילות לאורך זמן, שומרת מצב.

שאלה 4

מנהל הגדיר IOS IPS ו-true category all retired בלבד. אילו חתימות פעילות?
אף אחת – חייבים לבצע unretire (retired false) לקטגוריה כלשהי, למשל ios_ips basic.

שאלה 5

איזו מהפעולות הבאות אינה זמינה ל-IDS שנמצא מחוץ לנתיב התעבורה? 1. produce-alert 2. deny- packet-inline 3. reset-tcp-connection 4. produce-verbose-alert

2 - אי אפשר להפיל חבילה שכבר עברה; ה-IDS רואה רק עותק.

שאלה 6

מהו HIPS ומה יתרונו המרכזי על פני IPS רשתי?

Host-based IPS - תוכנה על המארח עצמו. יתרון: רואה תעבורה מוצפנת אחרי הפענוח ואת ההתנהגות בתוך המחשב (קבצים, זיכרון), ומגן גם כשהמחשב מחוץ לרשת הארגון.

5.13 מעבדה (3 שעות) - Packet Tracer IOS IPS

1. טופולוגיה: PC-A (10.1.1.10) — R1 — PC-B (10.2.2.10); שרת Syslog ברשת של PC-B. הגדירו log- ging לשרת.
2. ב-R1: ip ips config location flash:ipsdir, mkdir ipsdir, ip ips name IOSIPS, ip ips notify log all retired, ios_ips basic unretired. קטגוריות: 2004 0: retired false, enabled true, event-action produce-alert + deny-packet-inline.
3. שנו חתימה deny-packet-inline והשאירו ping produce-alert. עובר אך יש התראה - זו התנהגות IDS. דונו בהבדל.
4. החילו ip ips IOSIPS out על הממשק לכיוון PC-B (או in על הממשק מ-PC-A).
5. מ-PC-A: ping ל-PC-B ⇒ נכשל. בשרת ה-syslog: הודעת 2004-SIGNATURE: Sig: IPS-4. מ-PC-B: ping ל-PC-A ⇒ מצליח (הכיוון!). הסבירו.
6. הסירו את deny-packet-inline והשאירו ping produce-alert. עובר אך יש התראה - זו התנהגות IDS. דונו בהבדל.
7. show ip ips statistics, show ip ips all - כמה חבילות נבדקו?

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

שאלות נפוצות בפרק IDS/IPS, עם תשובות מוכנות.

ש: "אם IPS גם מזהה וגם חוסם, למה שמישהו יבחר IDS?"

ת: שלוש סיבות: (1) סיכון של false positive - בבית חולים או בבורסה, לחסום תעבורה לגיטימית בטעות גרוע מלהחמיץ התקפה. (2) ביצועים - IPS inline על קו מהיר יקר מאוד. IDS (3) פנימי (על SPAN רואה תנועה רוחבית בין מחשבים שלא עוברת בשום חומת אש. בפועל מפעילים את שניהם.

ש: "מה ההבדל בין IDS/IPS לאנטי-וירוס?"

ת: אנטי-וירוס מגן על דחא בשחמב מיצבק. IPS מגן על תשרה תרובעת בין מחשבים. HIPS (host-based) מטשטש את הגבול - הוא IPS שרץ על המחשב עצמו.

ש: "מה יותר גרוע - false positive או false negative?"

ת: תלוי במערכת. ב-IDS, false positive הוא רק רעש; false negative (התקפה שעברה בשקט) גרוע יותר. ב-IPS, false positive קסע מסוח (הזמנות לא נכנסות) - ולכן מנהלים לפעמים מכבים חתימות, וזה מוביל ל-false negatives. האיוון הזה נקרא "כוונון" (tuning) וזו עבודת ה-SOC.

ש: "מה ההבדל בין חתימה אטומית למורכבת?"

ת: אטומית בודקת תחא הליב (למשל Ping of Death - חבילה גדולה מדי) - מהירה, בלי זיכרון. מורכבת בודקת פצצ של חבילות לאורך זמן (למשל סריקת פורטים או SYN flood - חייבת לזכור מצב.

ש: "אם IPS מבוסס חתימות, איך הוא תופס התקפה חדשה שאין לה חתימה?"

ת: הוא לא, אם הוא רק מבוסס-חתימות - זו החולשה. לכן קיימות שיטות נוספות: זיהוי אנומליה (חריגה מ"נורמלי") ומוניטין (רשימות IP זדוניים). מערכות מודרניות משלבות כמה שיטות.

ש: "מה זה SPAN ולמה IDS צריך אותו?"

ת: SPAN הוא "שיקוף פורט" - המתג מעתיק את כל התעבורה לפורט שאליו מחובר ה-IDS. כך ה-IDS מקבל קתוע של הכול בלי לשבת בנתיב עצמו - ולכן אם ה-IDS נופל, הרשת ממשיכה לעבוד.

ש: "אילו פעולות IPS יכול לבצע כשהוא מזהה התקפה?"

ת: מ-alert בלבד (produce-alert), דרך הפלת החבילה (deny-packet-inline), הפלת כל החיבור (deny-connection-inline), חסימת התוקף לזמן (deny-attacker-inline), ועד שליחת TCP reset - הפעולה היחידה שגם IDS מחוץ לנתיב יכול לבצע.

ש: "מה זה CSA שמופיע בתכנית?"

ת: Cisco Security Agent - תוכנת HIPS ישנה שהותקנה על תחנות קצה וזיהתה התנהגות חשודה (לא רק חתימות). היא הופסקה ב-2010; היום התחום נקרא EDR (כמו Microsoft Defender, CrowdStrike).

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
IDS (Intrusion Detection System)	מערכת שמנטרת ומתריעה על ניסיונות חדירה, אך אינה חוסמת.
IPS (Intrusion Prevention System)	מערכת שמזהה וגם חוסמת אוטומטית ניסיונות חדירה.
inline / out-of-band	IPS יושב בנתיב התעבורה (inline); IDS (out-of-band). עותק מחוץ לנתיב.
HIPS	IPS מבוסס-מארח - תוכנה על המחשב/שרת עצמו; רואה גם תעבורה מוצפנת.
NIPS	IPS מבוסס-רשת - מכשיר בנתיב שמגן על מארחים רבים.
CSA (Cisco Security Agent)	תוכנת HIPS ישנה של סיסקו; היום התחום נקרא EDR.
חתימה (Signature)	תבנית ידועה של התקפה שהמערכת מחפשת בתעבורה.
חתימה אטומית	בודקת חבילה בודדת, ללא שמירת מצב (למשל Ping of Death).
חתימה מורכבת	בודקת רצף חבילות לאורך זמן, שומרת מצב (למשל סריקת פורטים).
זיהוי מבוסס-אנומליה	זיהוי חריגה מ'התנהגות נורמלית' שנלמדה (baseline).
Honeypot	מערכת פיתיון שאין לה שימוש לגיטימי; כל גישה אליה חשודה.
False Positive	אזעקת שווא - התראה על תעבורה לגיטימית.
False Negative	החמצה - התקפה אמיתית שלא זוהתה (המצב הגרוע ביותר).
True Positive / Negative	זיהוי נכון של התקפה (positive) או של תעבורה תקינה (negative).
Tuning (כוונון)	התאמת חתימות והחרגות כדי לצמצם false positives; עבודת ה-SOC.
Action (פעולה)	מה שה-IPS עושה בהתאמה: alert, deny-packet/connection/attacker, TCP reset.
SDEE	פרוטוקול מאובטח (HTTPS/XML) שדרכו תחנת ניהול שולפת אירועי IPS.
SPAN	שיקוף פורט - העתקת תעבורה לפורט שאליו מחובר IDS/מנתח.